

SAT 3812: Cyber Security I

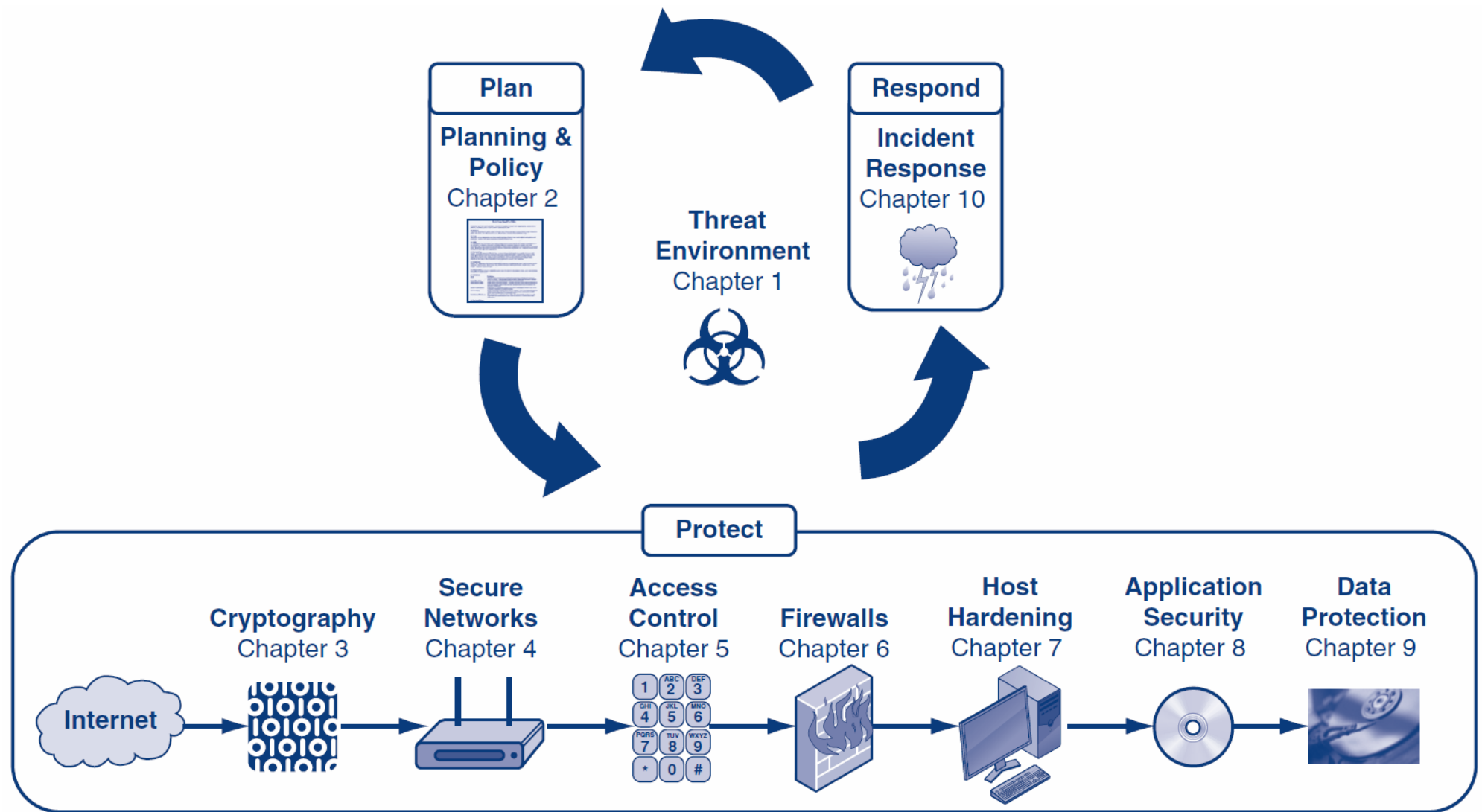
Security Policy, Planning, Regulations,
and Risk Analysis

Instructor: Yunlong Xing



Learning Objectives

- Explain the plan–protect–respond security management cycle.
- Describe compliance laws and regulations.
- Describe organizational security issues.
- Describe risk analysis and risk management
- Describe the adversary model.
- Understand cyber ethics and code of ethics
- Know fundamental security design principles
- Know governance frameworks.



2.1: Management is the Hard Part

- **Technology Is Concrete**

- Can visualize devices and transmission lines
- Can understand device and software operation

- **Management Is Abstract**

- **Management Is More Important**

- Security is a process, not a product (Bruce Schneier)

2.1: The Need for Comprehensive Security

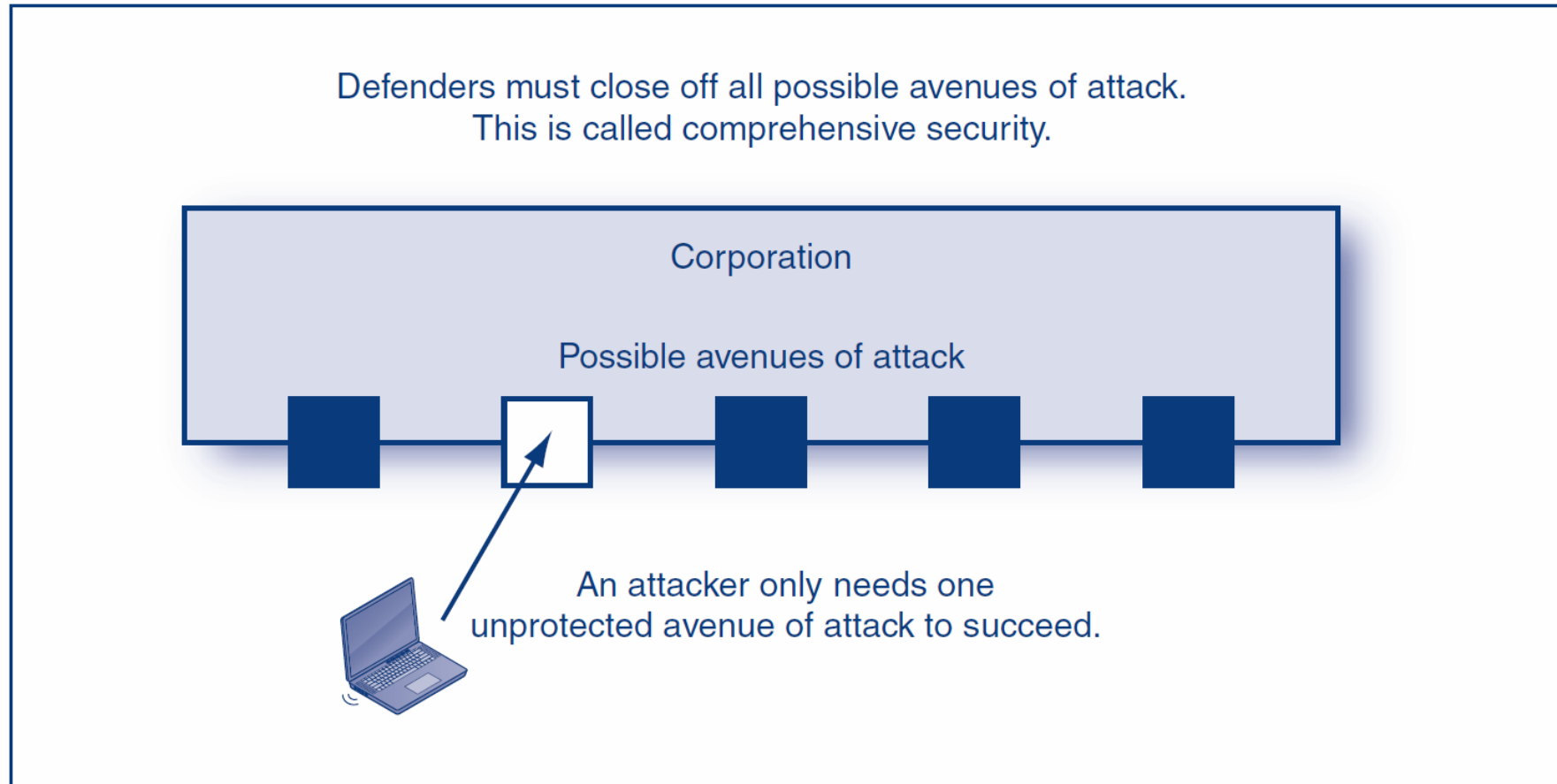


FIGURE 2-3 The Need for Comprehensive Security (Study Figure)

2.1: Weakest Link Failure

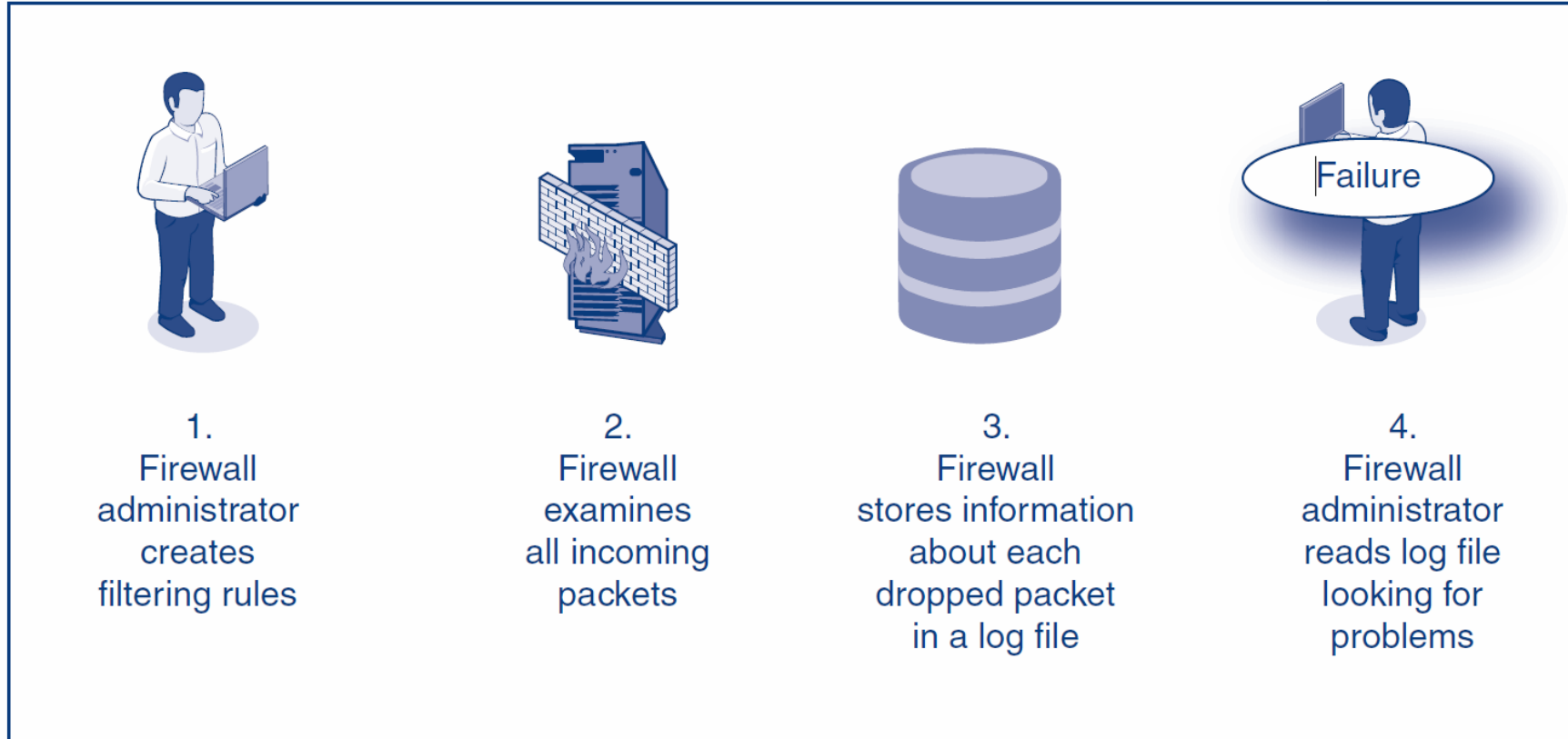


FIGURE 2-4 Weakest Link Failure (Study Figure)

A failure in any component will lead to failure for the entire system

2.1: Security Management Is a Disciplined Process

- **Complex**

- Cannot be managed informally

- **Need Formal Processes**

- **Why do we need a formal process for security management?**
- Planned series of actions in security management
- Annual planning
- Processes for planning and developing individual countermeasures

2.1: The Plan-Protect-Respond Cycle for Security Management

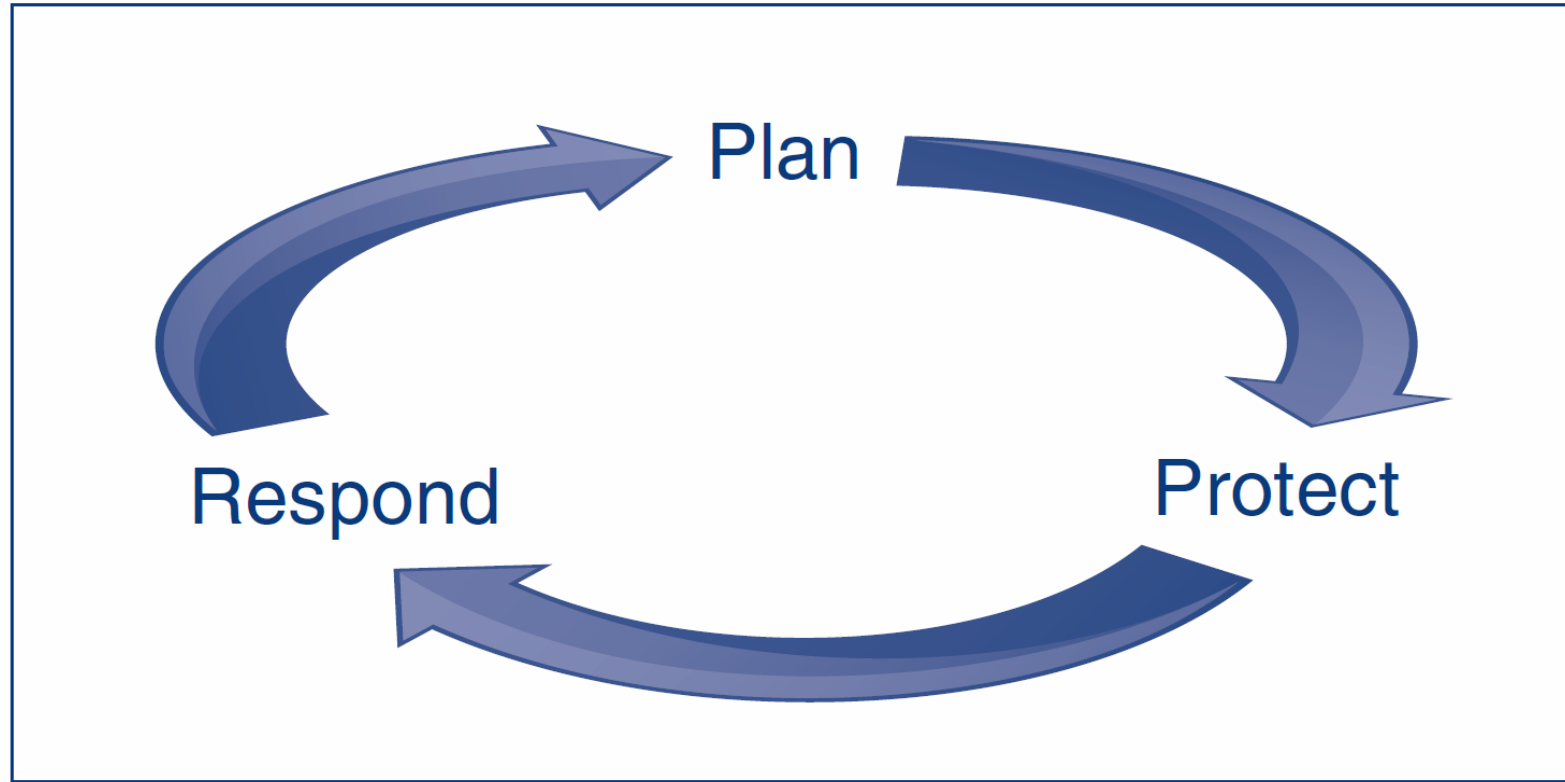
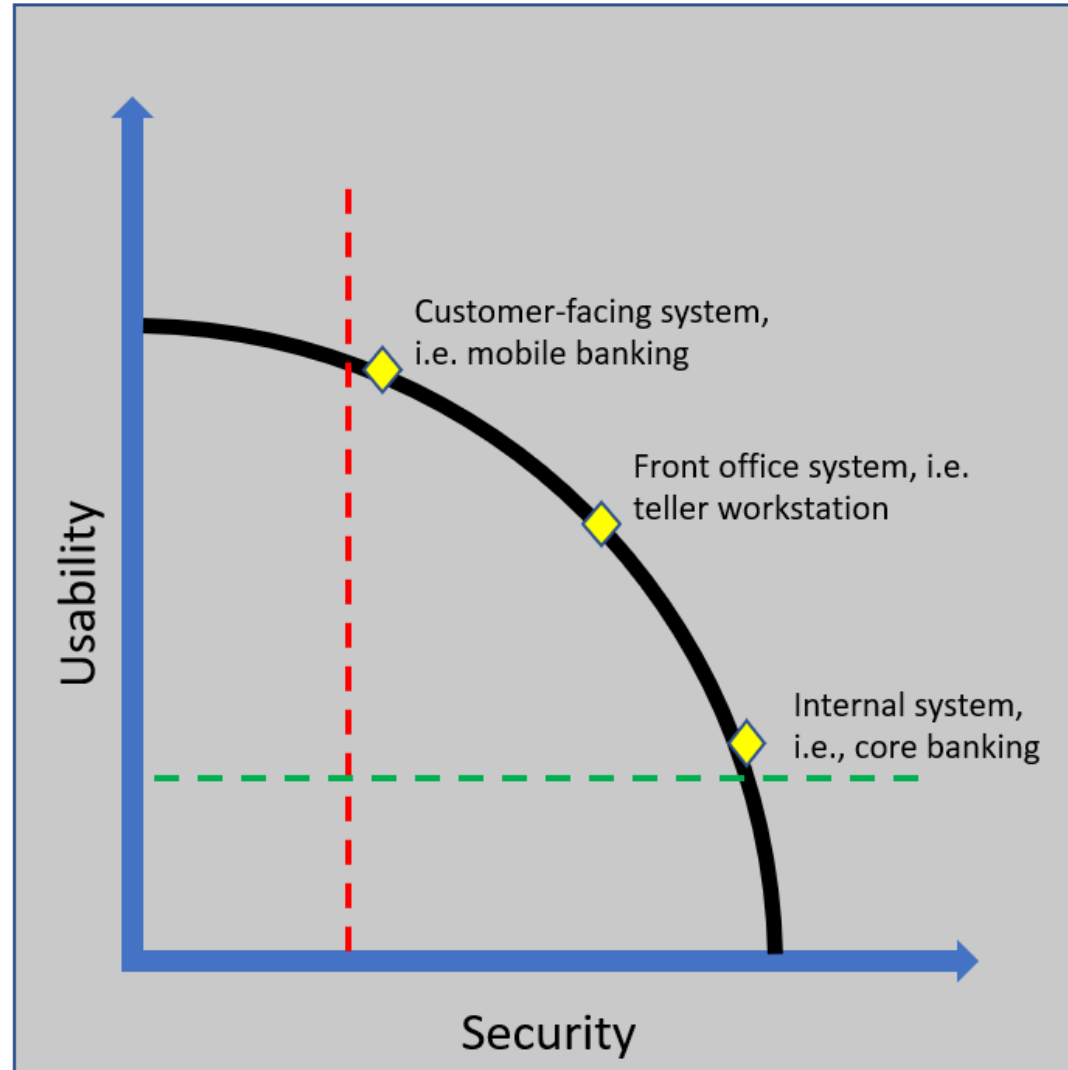


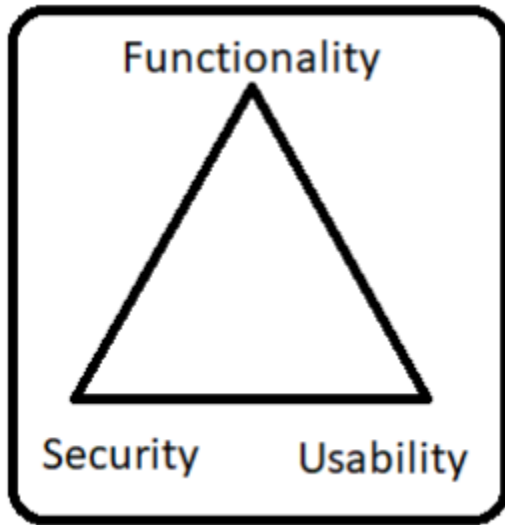
FIGURE 2-6 The Plan–Protect–Respond Cycle for Security Management

Dominates security management thinking

Security vs Usability



Security, Functionality and Usability Triangle



Discussion:

The battle between usability, security, and functionality is often observed throughout the workplaces.

Give a couple of examples.

Example 1. Password management: strong passwords, update passwords periodically.

Example 2: Files shared on the cloud without proper configuration.

2.1: Strategic IT Security Planning

▶ Identify Current IT Security Gaps

▶ Identify Driving Forces

- The threat environment
- Compliance laws and regulations
- Corporate structure changes, such as mergers

▶ Identify Corporate Resources Needing Protection

- Enumerate all resources
- Rate each by sensitivity

2.2: Legal Driving Forces

■ Compliance Laws and Regulations

- Compliance laws and regulations create requirements for corporate security
 - Documentation requirements are strong
 - Identity management requirements tend to be strong
- Compliance can be expensive
- There are many compliance laws and regulations, and the number is increasing rapidly

Legal Framework in a Data Breach

Customer Privacy Laws

- *Federal and state identity theft laws and regulations*
 - *Requiring customer notice*
 - *Requiring information security programs*
- *HIPAA / Medical information regulation*
- *Gramm Leach Bliley / Financial information regulation*
- *Regulations for specific industries (e.g., FCC CPNI Regulations)*
- *Laws governing specific information (e.g., Social Security number statutes)*
- *Negligence / Consumer protection laws*

Authorized Use Statutes

- *Computer Fraud & Abuse Act (CFAA)*
- *Electronic Communications Privacy Act (ECPA)*
- *Stored Communications Act (SCA)*

Surveillance / Information Security Law

- *Federal & State Wiretapping Statutes*
- *Invasion of Privacy*

Property Law

- *Larceny / Conversion*
- *Trade Secrets*
- *Copyright / Digital Millennium Copyright Act (DMCA)*

Organizational Issues

- Roles of personnel in planning and managing security
 - Board of Directors
 - Senior Management
 - Chief Information Security Officer (CISO)
 - IT Management (CIO, IT Director, etc)
 - Functional Area Management
 - Information Security personnel
 - End users

2.3: Organizational Issues

- **Chief Security Officer (CSO)**

- Also called chief information security officer (CISO)

- **Where to Locate IT Security?**

- Within IT
 - Compatible technical skills
 - CIO will be responsible for security
 - Outside of IT
 - Gives independence
 - Hard to blow the whistle on IT and the CIO
 - This is the most commonly advised choice

2.3: Organizational Issues

■ Where to Locate IT Security?

- Hybrid
 - Place planning, policy making, and auditing outside of IT
 - Place operational aspects such as firewall operation within IT

2.3: Organizational Issues

■ Top Management Support

- Budget
- Support in conflicts
- Setting personal examples

2.3: Organizational Issues

■ Relationships with Other Departments

- Special relationships
 - Ethics, compliance, and privacy officers
 - Human resources (training, hiring, terminations, sanction violators)
 - Legal department

2.4: Risk Analysis

■ Realities

- Can never eliminate risk
- “Information assurance” is impossible

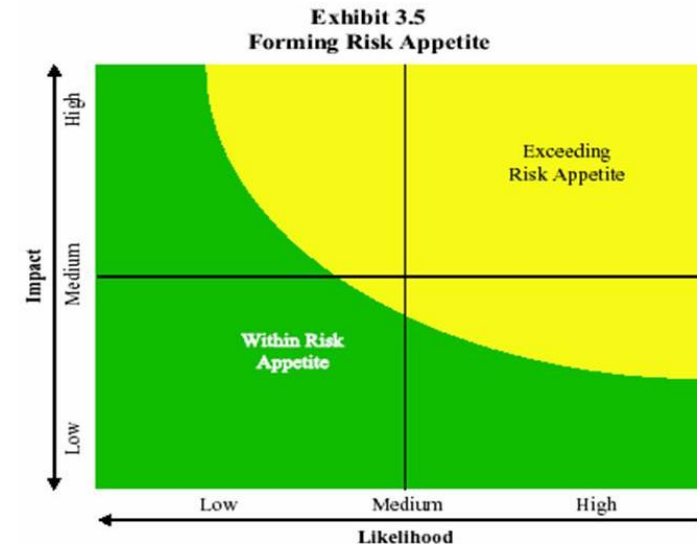
■ Risk Analysis

- Goal is reasonable risk
- Risk analysis weighs the probable cost of compromises against the costs of countermeasures
- Also, security has negative side effects that must be weighed

2.4: Risk Appetite

- In risk management, risk appetite is the level of risk an organization is prepared to accept.
- Risk appetite constraints are not easy to define; every organization can tolerate different levels of risk.

Risk Appetite



Source : COSO ERM

2.4: Risk Analysis

- Asset Value (AV)
- X Exposure Factor (EF)
 - Percentage loss in asset value if a compromise occurs
- = Single Loss Expectancy (SLE)
 - Expected loss in case of a compromise

Single Loss Expectancy (SLE)

- SLE
- X Annualized Rate of Occurrence (ARO)
 - Annual probability of a compromise
- = Annualized Loss Expectancy (ALE)
 - Expected loss per year from this type of compromise

Annualized Loss Expectancy (ALE)

**See the Risk Analysis PPT for more
information.**

2.4: Responding to Risk

■ Risk Reduction

- The approach most people consider
- Install countermeasures to reduce harm
- Makes sense only if risk analysis justifies the countermeasure

■ Risk Acceptance

- If protecting against a loss would be too expensive, accept losses when they occur
- Good for small unlikely losses
- Good for large but rare losses

2.4: Responding to Risk

■ Risk Transference

- Buy insurance against security-related losses
- Especially good for rare but extremely damaging attacks
- Does not mean a company can avoid working on IT security
- If bad security, will not be insurable
- With better security, will pay lower premiums

2.4: Responding to Risk

- **Risk Avoidance**

- Not to take a risky action
- Lose the benefits of the action
- May cause anger against IT security

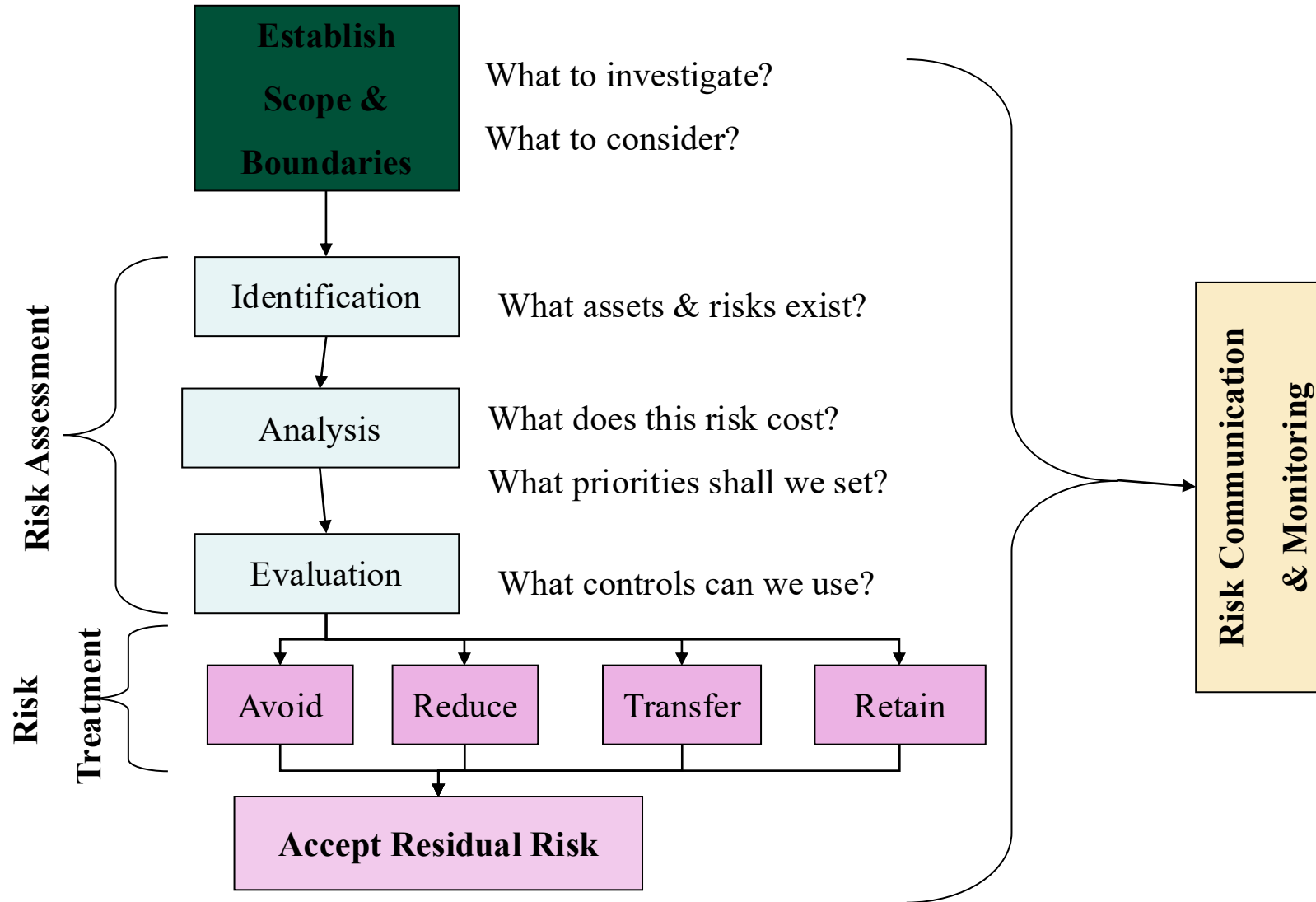
- **Recap: Four Choices When You Face Risk**

- Risk reduction
- Risk acceptance
- Risk transference
- Risk avoidance

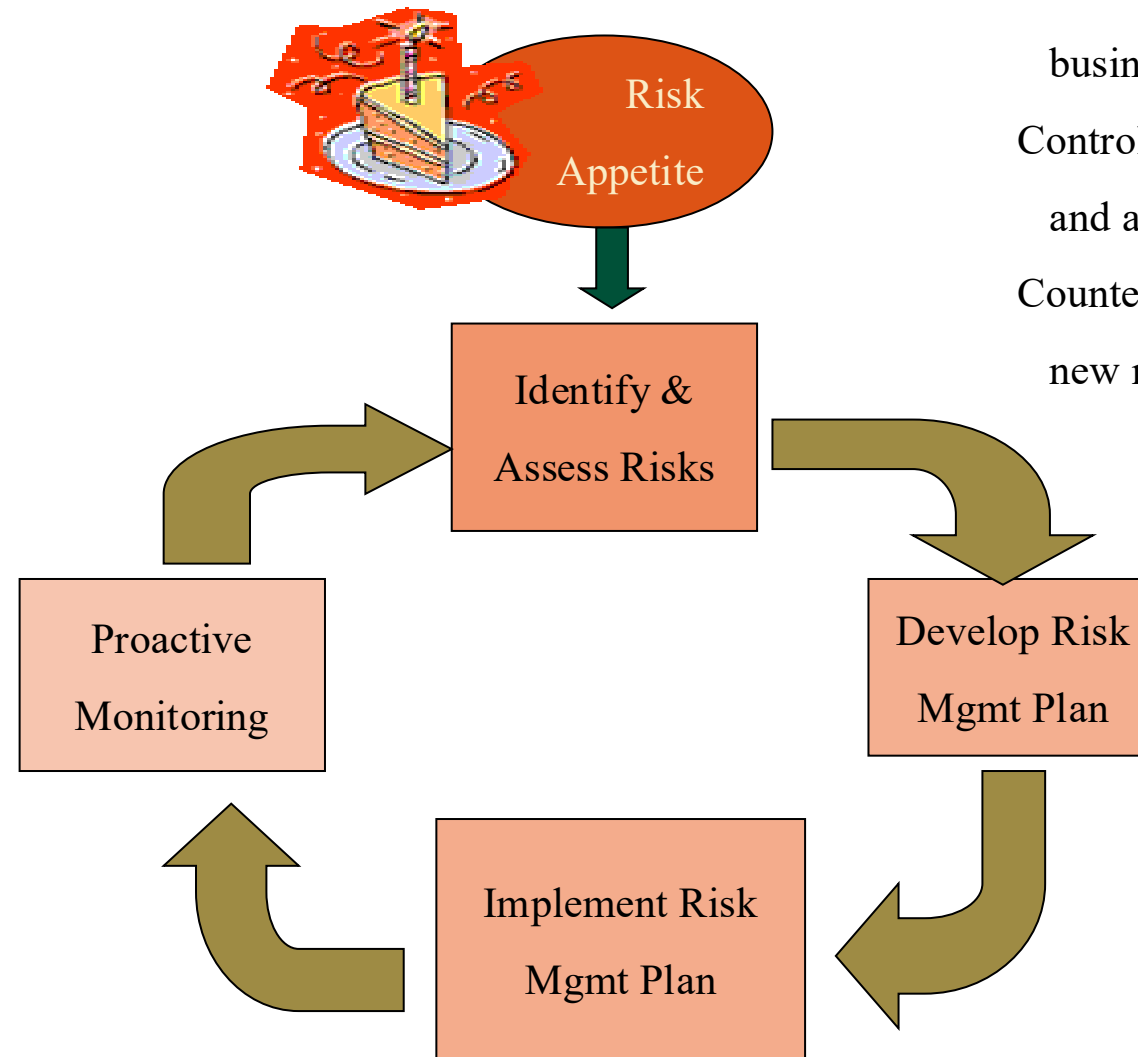
Risk Management Model

- Risk identification
- Qualitative risk analysis
- Quantitative risk assessment
- Risk response planning
- Risk monitoring and control

Risk Management Process



Continuous Risk Management Process



Risks change with time as

business & environment changes

Controls degrade over time

and are subject to failure

Countermeasures may open

new risks

2.6: Ethics

■ Ethics

- A person's system of values
- Needed in complex situations
- Different people may make different decisions in the same situation
- Companies create codes of ethics to give guidance in ethical decisions

2.6: Making Ethical Decisions

- Ethical decision-making refers to the process of evaluating and choosing among alternatives in a manner consistent with ethical principles.
- Ethics-based decision tools
 - In making ethical decisions, it is necessary to perceive and eliminate unethical options and select the best ethical alternative.

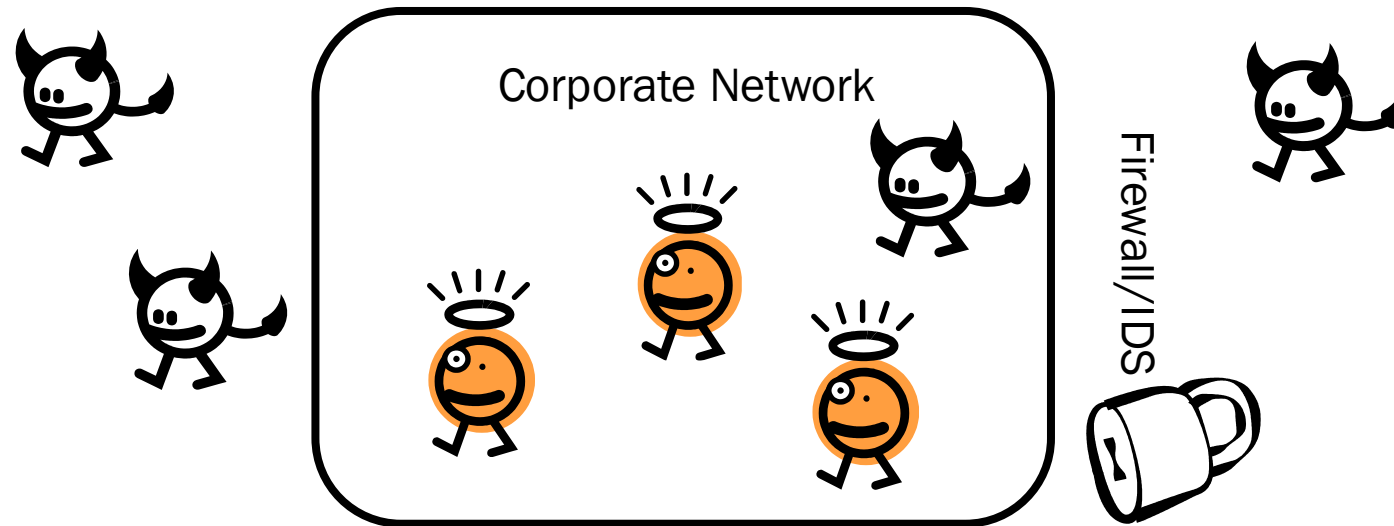
2.6: Oversight

■ Auditing

- Internal and external auditing may be done
- Periodic auditing gives trends
- Unscheduled audits trip up people who plan their actions around periodic audits

2.6: Insider Problems

- A malicious insider is an adversary who operates inside the trusted computing base, basically a trusted adversary.
- The insider threat is an adversarial model encompassing all possible malicious insiders.



2.6: The Insider – Who are They?

- Who is an insider?
 - Employees, contractors, business partners, customers, etc.
 - Well-intentioned insider actions
- CSI/FBI Survey key findings (2010)
 - **Insider attacks** have now surpassed viruses as the most common cause of security incidents in the enterprise
 - 25% of respondents felt that over 40% of their financial losses were due to **malicious actions by insiders**
- Identity Theft Resource Center findings (2011)
 - Data breach due to **insider theft** – 13% (other causes – card-skimming, data lost on the move, etc.)
- U.S. Secret Service/CERT/Microsoft E-Crime report (2010)
 - 67% of the respondents reported that **insider attacks** are the most costly and damaging type of attacks

2.6: The Fraud Triangle of Insiders

■ Behavioral Awareness

- Misbehavior often occurs before serious security breaches
- The fraud triangle indicates motive.

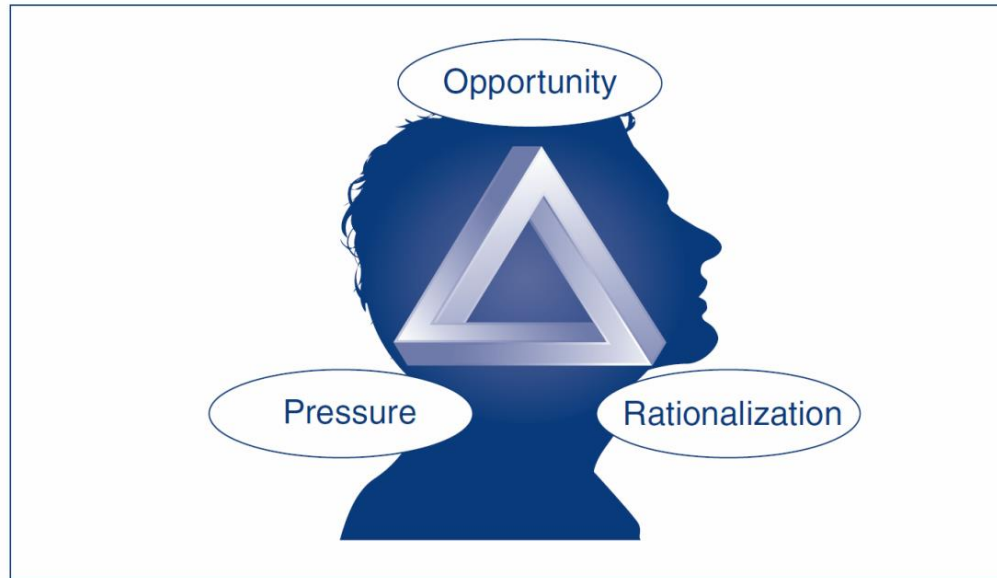


FIGURE 2-24 Fraud and Abuse Triangle

Security Baseline

- A "Security Baseline" defines a set of basic security objectives which must be met by any given service or system.
- The objectives are chosen to be pragmatic and complete, and do not impose technical means.
- For example:
 - Security Baseline for Servers, PCs and Laptops used in a Production Environment

2.8 Fundamental Security Design Principles

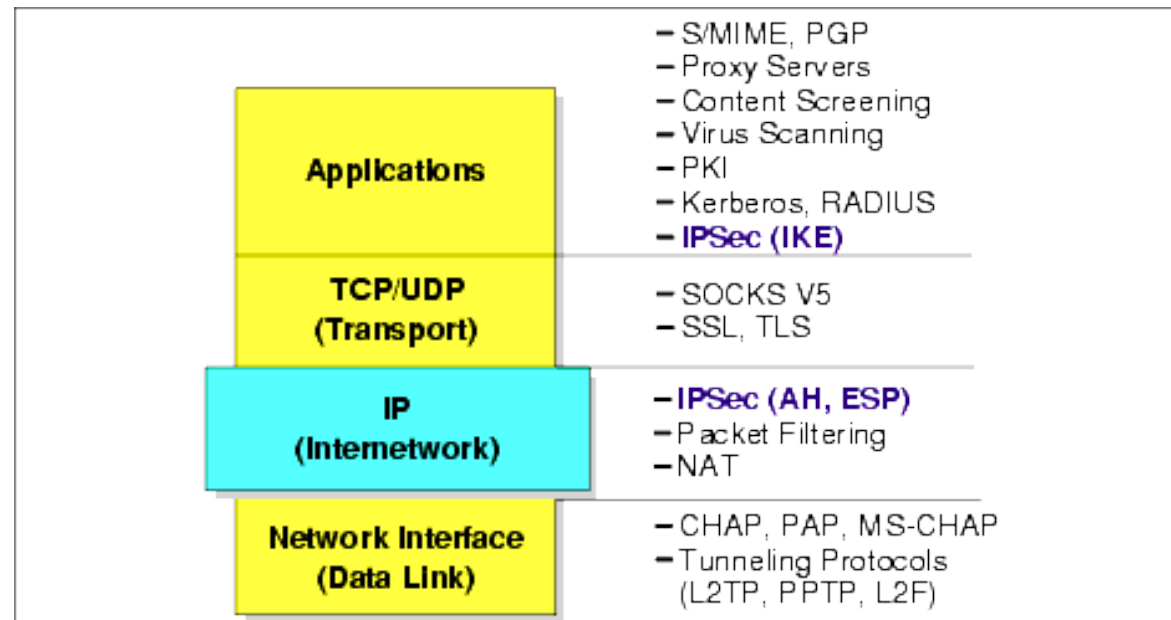
- Separation (of domains)
- Isolation
- Encapsulation
- Least Privilege
- Simplicity (of design)
- Minimization (of implementation)
- Fail Safe Defaults / Fail Secure
- Modularity
- Layering
- Least Astonishment
- Open Design
- Complete Mediation
- Minimize Trust Surface
- Usability
- Trust relationship

Least Privilege

- The principle of least privilege says to allow the minimum number of privileges necessary to accomplish the task.
 - When a person gets a new computer, s/he installs or logs onto the computer using an administrative account. This account has privileges to install software, add users, add hardware, and add and delete almost any program or file. The account is all powerful and must be used wisely.
 - If a person uses a browser to access a website that contains malware and they are running as administrator, it is more likely that malware could be installed. If the person was running as a regular user with minimal privileges, the malware would not have been installed.

Layering

- Layering in computer security implements multiple layers of computer security, each one having to be conquered before moving to the next. Also called Defense in Depth.
- A good example is OSI model with security.



Domain Separation

- A domain is a generic term. It could be a region governed by a king; it could be a website, or an area of control.
- Inside a computer system, there are also domains.
 - For example, most hardware microprocessors have a supervisor domain (sometimes referred to as a supervisor state or privileged state) and a user domain. In supervisor state, privileged hardware instructions can be executed.
 - An operating system uses these hardware domains to implement mechanisms that protect it from interference by user written programs and purchased applications. The operating system code runs in supervisor state, while the user programs run in the user domain.

Isolation

- A process is a program running in a computer. Processes running in a computer have their own portion of memory called the address space.
 - The address space is an area of memory that only one running program can access.
- In addition to process isolation, it is also possible to have operating isolation.
 - Programs such as VMWare or Virtual Box enable multiple operating systems to execute on the same computer without interfering with other program.
 - In this context, each OS is viewed as a process, to be kept separate from the other processes (OSs). Program running in each OS, should not be aware of programs running on another OS, nor should they be aware of the existence of another OS.

Simplicity

- When designing a product, hardware or software, simplicity should be a goal.
 - Simplicity is a design principle at Apple, especially with the iPhone. There is a single button. People understand how to use the device without having to read a manual.
- Simplicity allows a person to better understand hardware and software.
 - Without the clutter of unnecessarily complicated code and interfaces, the software will be more understandable by people that will update the code when requirements change. It will be easier to understand by the testers and they will be able to spot problems sooner.
 - By keeping software as simple and as focused as possible, the reliability and security is greatly increased.

Minimization (of Attack Surfaces)

- The attack surface of an application are the places in a program where users and other programs can enter and extract data.
 - As software increases in size, the ability to secure the program becomes more difficult due to the sheer size and increased complexity of the software.
- The goal of minimization is to simplify and decrease the number of ways that software can be exploited.
 - This can include turning off ports that are not needed, reduce the amount of code running, use the concept of least privilege and turn off unneeded features.
 - Remove unnecessary components
 - Turn off unnecessary services
 - Close unnecessary ports

Fail Safe Defaults/Fail Secure

- Unless a subject is given explicit access to an object, it should be denied access to the object.
 - Default access to an object is none
 - Access Control Lists (ACLs), firewall examples.
 - Restricting privileges at the time of creation
 - Think about all those default passwords and how they were exploited by hackers.